

An Overview of Malware

Malware:

Malicious software:

- These can be very bad

Gather information:

- Keystrokes

Show you advertising:

- Big Money

Viruses and worms:

- Encrypt your data
- Ruin your day

Malware types and methods:

- Viruses
- Worms
- Ransomware
- Trojan Horse
- Rootkit
- Keylogger
- Spyware
- Bloatware
- Logic bomb

How you get malware:

These all work together:

- A worm takes advantage of a vulnerability
- Installs malware that includes a remote access backdoor
- Additional malware may be installed later

Your computer must run a program:

- Email link - don't click links
- Web page pop-up
- Drive-by downloads
- Worm

Your computer is vulnerable:

OS - Keep OS updated!

Your data is valuable:

Personal data:

- Family pictures and videos
- Important documents

Organization data:

- planning documents
- Employee personally identifiable information (PII)
- Financial Information
- Company private data

How much is it worth?:

- There's a number

Ransomware:

A particularly nasty malware:

- Your data is unavailable until you provide cash

Malware encrypts your data files:

- Pictures, documents, music, movies, etc.
- Your OS remains available
- They want you running not working

You must pay the attackers to obtain the decryption key:

- Untraceable payment system
- An unfortunate use of public-key cryptography

Protecting against Ransomware:

Always have a backup:

- An offline backup, ideally

Keep your OS up to date:

- Patch those vulnerabilities

Keep your apps up to date:

- Security patches

Keep your antivirus/ anti-malware signatures up to date:

- New attacks every hour

Keep your system always up to date

Viruses and Worms

Virus:

Malware that can reproduce itself:

- It needs you to execute a program

Reproduce through file systems or the network:

- Just running a program can spread a virus

May or may not cause problems:

- Some viruses are invisible, some are annoying

Anti-Virus is very common:

- Thousands of new viruses every week
- Is your signature file updated?

Virus types:

Program viruses:

- Its part of the appllaction

Boot sector viruses:

- Who needs an OS?

Script Viruses:

- Operating system and browser based

Macro viruses:

- Common in Microsoft office

Filess virus:

A stealth attack:

- Does a good job avoiding anti-virus detection

Operates in memory:

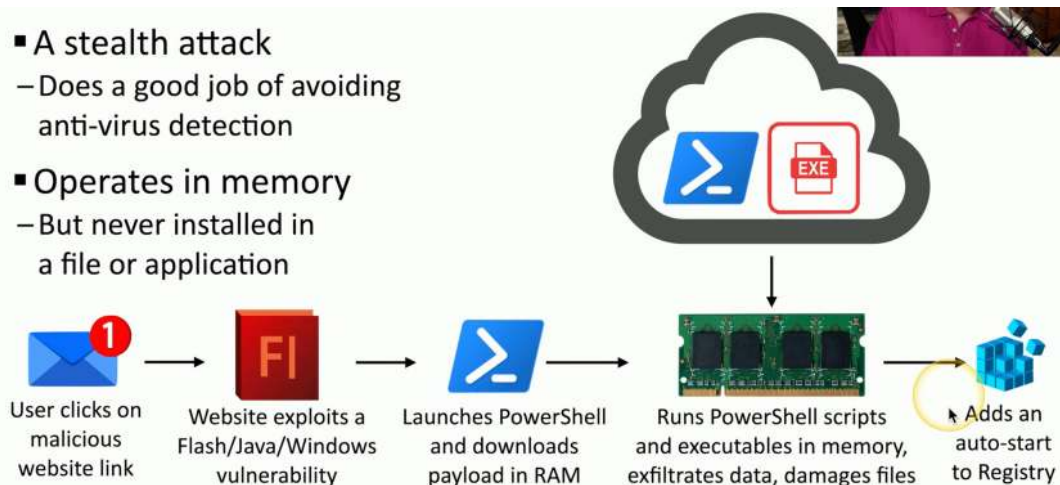
- But never installed in a file or application

▪ A stealth attack

- Does a good job of avoiding anti-virus detection

▪ Operates in memory

- But never installed in a file or application



Worms:

Malware that self-replicates:

- Doesn't need you to do anything
- Uses the network as a transmission medium
- Self-propagates and spreads quickly

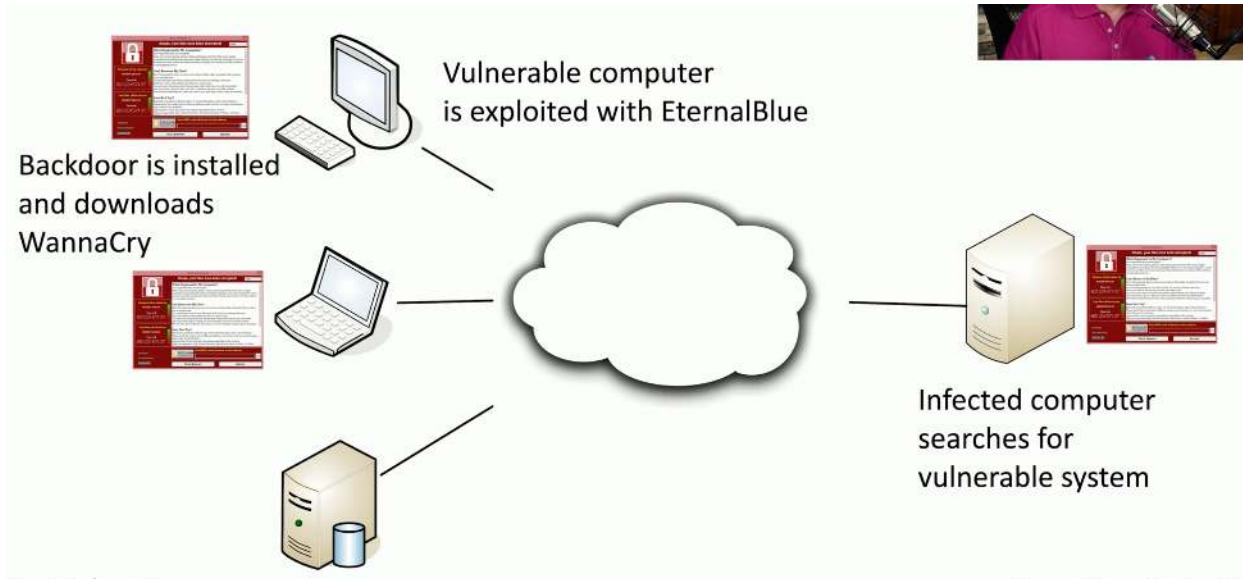
Worms are pretty bad things:

- Can take over many systems very quickly

Firewalls and IDS/IPS can mitigate many worm infestations:

- Doesn't help much once the worm gets inside.

Wannacry Worm:



Spyware and Bloatware

Spyware:

Malware that spies on you:

- Advertising, id theft, affiliate fraud

Can trick you into installing:

- Peer to peer, fake security software

Browser monitoring:

- Capture surfing habits

Keyloggers:

- Capture every keystroke
- Send your keystrokes back to the attacker

Protecting against anti-virus / anti-malware:

- Always have the latest signatures

Always know what your installing:

- And watch your options during the installation

Where's your backup?:

- You might need it someday
- Cleaning adware isn't easy

Run some scans:

- Malware bytes

Bloatware:

A new computer or phone:

- Includes the OS and important apps

Also includes applications you didn't expect:

- And often don't need

Apps are installed by the manufacturer:

- You don't get a choice

Uses valuable storage space:

- may also add to overall resource usage
- The system may be slower than expected
- Could open your systems to exploits

Removing bloatware:

Identify and remove:

- This may be easier said than done

Use built in uninstaller:

- Works for most applications

Some apps have their own uninstaller:

- That's how bad they are

Third party uninstaller and cleaners:

- Probably not the first option
- Always have a backup

Other types of Malware

Keyloggers:

Your keystrokes contain valuable information:

- Website login URLs, password, email messages

Save all of your input:

- Send it to the bad guys

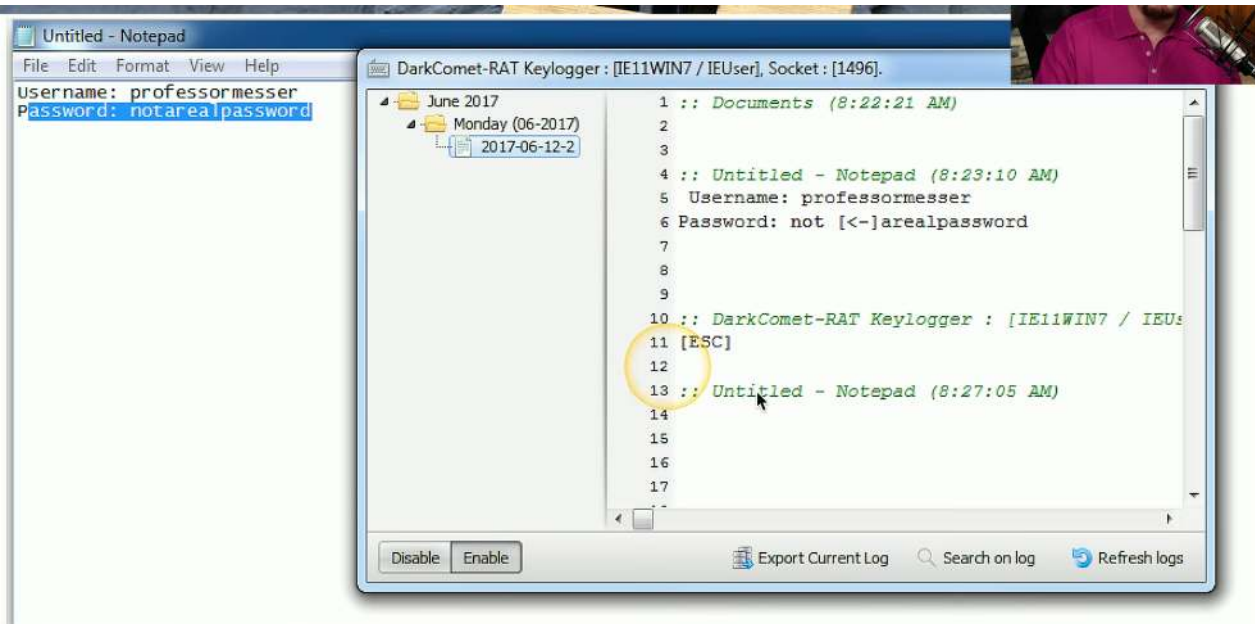
Circumvents encryption protections:

- Your keystrokes are in the clear

Other data logging:

- Clipboard logging, screen logging,
- Instant messaging, search engine queries

Key logger in action:



What's happening in this screenshot is that the key logger is using the software DarkComet-RAT.

Where it logs everything that is happening on that pc is you can see on the right.

Logic Bomb:

Waits for a predefined event:

- Often left by someone with a grudge

Time bomb:

- Time or date

User event:

- Logic Bomb

Difficult to identify:

- Difficult to recover if it goes off

Real world logic bombs:

March 19th, 2013 South Korea:

- Email with malware attachment sent to south korean orgs.
- Posed as a bank email
- Trojan installs malware

March 20th, 2013, 2pm local time:

- Malware time-based logic bomb activates
- Storage and master boot record deleted, system reboots

Boot device not found

Please install an operating system on your hard disk - was the result on ATMS around the country

Preventing a logic bomb:

Difficult to recognize:

- Each is unique
- No predefined signatures

Process and procedures:

- Formal change control

Electronic monitoring:

- Alert on changes
- Host-Based intrusion detection, tripwire, etc.

Constant auditing:

- An admin can circumvent existing systems

Rootkits:

Originally a UNIX technique:

- The root in rootlet

Modifies core system files:

- art of the kernel

Can be invisible to the OS:

- Won't see it in task manager

Also invisible to traditional anti-virus utilities:

- If you can't see it, you can't stop it.

Finding and removing rootkits:

Look for the unusual:

- Ant-malware scans

Use a remover specific to the rookit:

- Usually built after the rootkit was discovered

Secure boot with UEFI:

- Security in the BIOS

Physical Attacks

Old School Security:

- No keyboard, no mouse, no command line

Many different ways to circumvent digital security:

- A physical approach must be considered

If your have physical access to a server, you have full control:

- An OS can't stop an in person attack

Door locks only keep out the honest people:

- There's always a way in

Brute force:

The physical version:

- No password required

Push through the obstruction:

- Brawn not brains

Check your physical security:

- Check the windows
- Try the doors

Attackers will try everything:

- You should be prepared for anything

RFID cloning:

RFID is everywhere:

- Access badges
- Key fobs

Duplicators on amazing:

- Less than \$50

The duplication proc essentially takes seconds:

- Read one card
- Copy another

This is why we have MFA:

- Use another factor with the card

Environmental attacks:

Attack everything supporting the technology:

- The operating environment

Power monitoring:

- An obvious attack

HVAC and humidity controls:

- Large data must be properly cooled

Fire suppression:

- Watch for smoke or fire

Denial of Service

Force a service to fail:

- Overload the service

Take advantage of a design failure or vulnerability:

- Keep your systems patched!

Cause a system to be unavailable:

- Competitive advantage

Create a smokescreen for some other exploit:

- Precursor to a DNS spoofing attack

Doesn't have to be complicated:

- Turn off power

A "friendly" DOS:

Unintentional DOSing:

- Its not always a ne'er-do-well:

Network DOS:

- Layer 2 loops without STP

Bandwidth DOS:

- Downloading multi-gigabyte linux distribution over a DSL line

The water line breaks:

- Get a good shop vacuum

Distributed denial of service (DDOS):

- Launched an army of computers to bring down a service:
- Use all the bandwidth or resources - traffic spike

This is why the attackers have botnets:

- Thousands or millions of computers at your command
- At its peak, Zeus botnet infected over 3.6 million pcs
- Coordinated attack

Asymmetric threat:

- The attacker may have few resources than the victim

DDOS reflection and amplification:

Turn your small attack into a big attack:

- Often reflected off another device or service

An increasingly common network DDoS technique:

- Turn internet services against the victim

Uses protocols with little (if any) authentication or checks:

- NTP, DNS, ICMP
- A common example of protocol abuse

```

$ dig ANY isc.org
;; Truncated, retrying in TCP mode.

; <<>> DiG 9.8.3-P1 <<>> ANY isc.org
;; global options: +cmd
;; Got answer:
;; ->HEADER<<- opcode: QUERY, status: NOERROR, id: 27443
;; flags: qr rd ra; QUERY: 1, ANSWER: 4, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;isc.org.                IN      ANY

;; ANSWER SECTION:
isc.org. 1712 IN DNSKEY 257 3 5 BEAAAAOHQBBrhQbtphgq2wQUpEQ5t4DtUHxoMVFu2hWLDmvoOMRXjGr hhCeFvAZih7yJHf8ZGfW6hd38hXG/
xylYCO6Krpbd0jwx8YMXLAS/KA+ u50WIL8ZRI6KTbsYVMF/Qx5RiNbPClw+vT+U8eXEm020jIS1ULgqy3 47cBB1zMnnz/4L3pA0da9CbKj3A254T515sNIMCwsB8/2+2E63/zZrQz
Bkj0BrW/9Bexjpiks3jRhZatEsXn3dT47R09Uix5Wc3t+xzqZ7+ysyl K00edS39Z7SDmsn2eA0FKtQpwA6LXeg2w+jxmw3oA81VUgEf/rzeC/bB yBNs070aEFTd
isc.org. 1712 IN DNSKEY 256 3 5 AwEAAbDs5ksq3roEgVfIN+HHZpQErVe51OpQ6bnJRDH/BSUisBM8gvgd ZGIdctVRY18vgA3cpc//
YE4vpNrDsfgGfiyz+Fd2pCJTXXGm6mDoAAMLJ FrG64gYVdby2AnI7sonZ1T5PHJ50dKBhhf0Pd/+SgKNIF25wh1UzFRCP CXznwDER
isc.org. 1712 IN RRSIG DNSKEY 5 2 7200 20170712230419 20170612230419 12892 isc.org. MZ8PU+4k/
wwHDw3jdyzUpm74MFhbFvCem1j61ho0gkDGNhEqn8/yC1Fs oaT7PK9U8hkn1rppp/os08yU1fegPsvO1mhezTFIEHTP+JPJ56V00G5A
a9QHQtVO2FOPuR7HW2AQysldfL9pfvwo1Kkzm4yuuhrM2BqhMeS2imo6 VvolWqHyE58d0HoyeyImcvmNb45qor4spKZR9A1hdxesYgI1tosw9Ttd
PswkyO3rizmFjABzcXDUEKSlodPRr1hZd6rNRRacIeiskPw6E6wTnT 0RzOM7nFBDIKetixA59x1PpIN2t+xl1zu8tQ5NsMF2CJK+b5LZTjovEg 9ho9NA==
isc.org. 1712 IN RRSIG DNSKEY 5 2 7200 20170712230419 20170612230419 60321 isc.org. fVnJffUYaDDrUYbo4hhPwKzjyzB6QEEXLWao5jyaIDpEYL/
aymTk6/51 nAubio2qdlgFinpoHmkaRDVdV1DG/6CwmA2/tVAZs577q3KKEYjbnQ IR/bgkhxPtti/7+65YrPZ9yrNiPp85LbNTmJyeuuQD4cam1iS9qHn1v6 618=

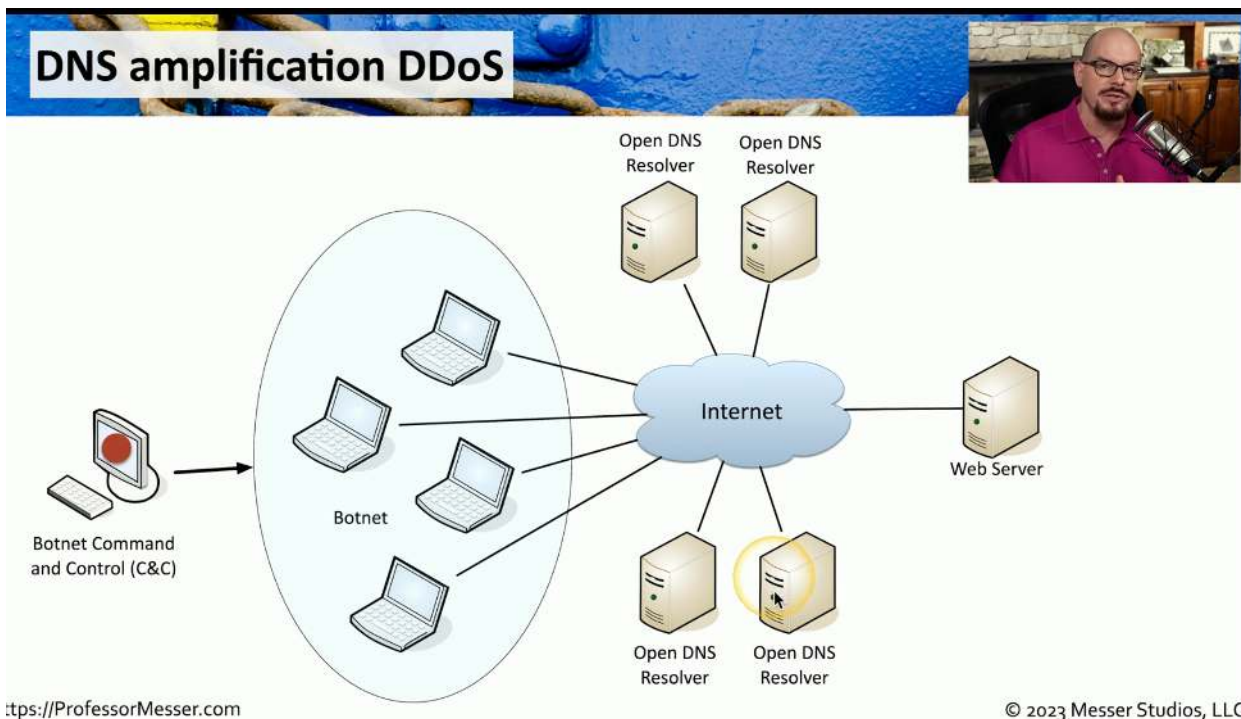
;; Query time: 13 msec
;; SERVER: 75.75.75.75#53(75.75.75.75)
;; WHEN: Fri Jun 16 17:36:51 2017
;; MSG SIZE rcvd: 912

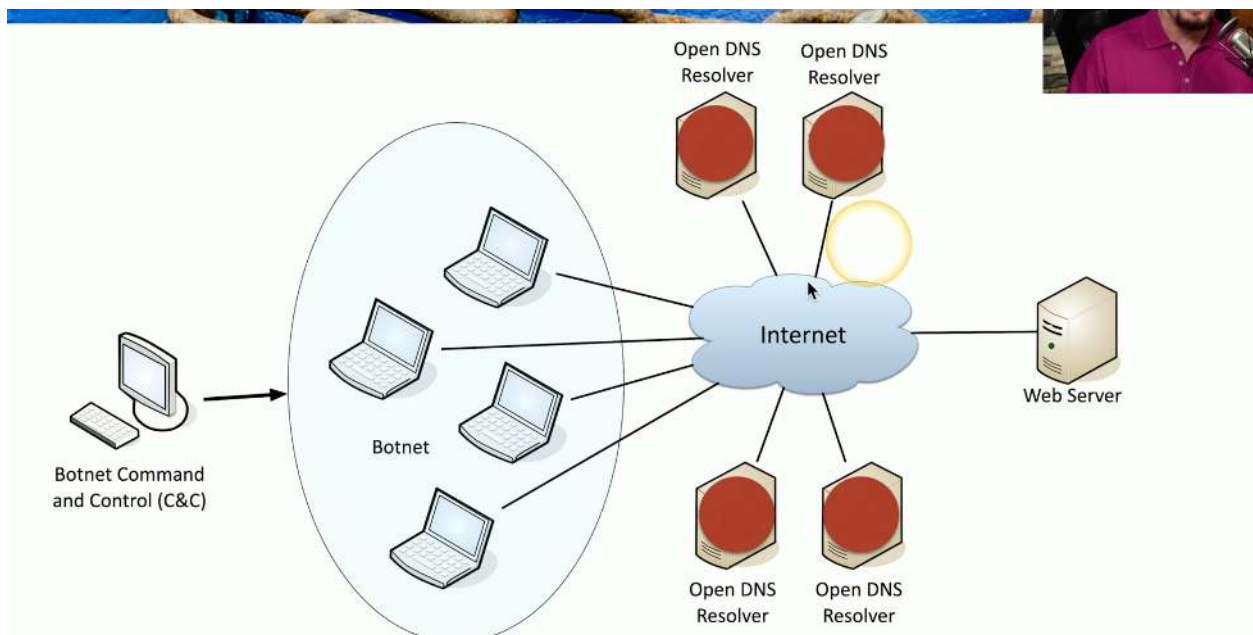
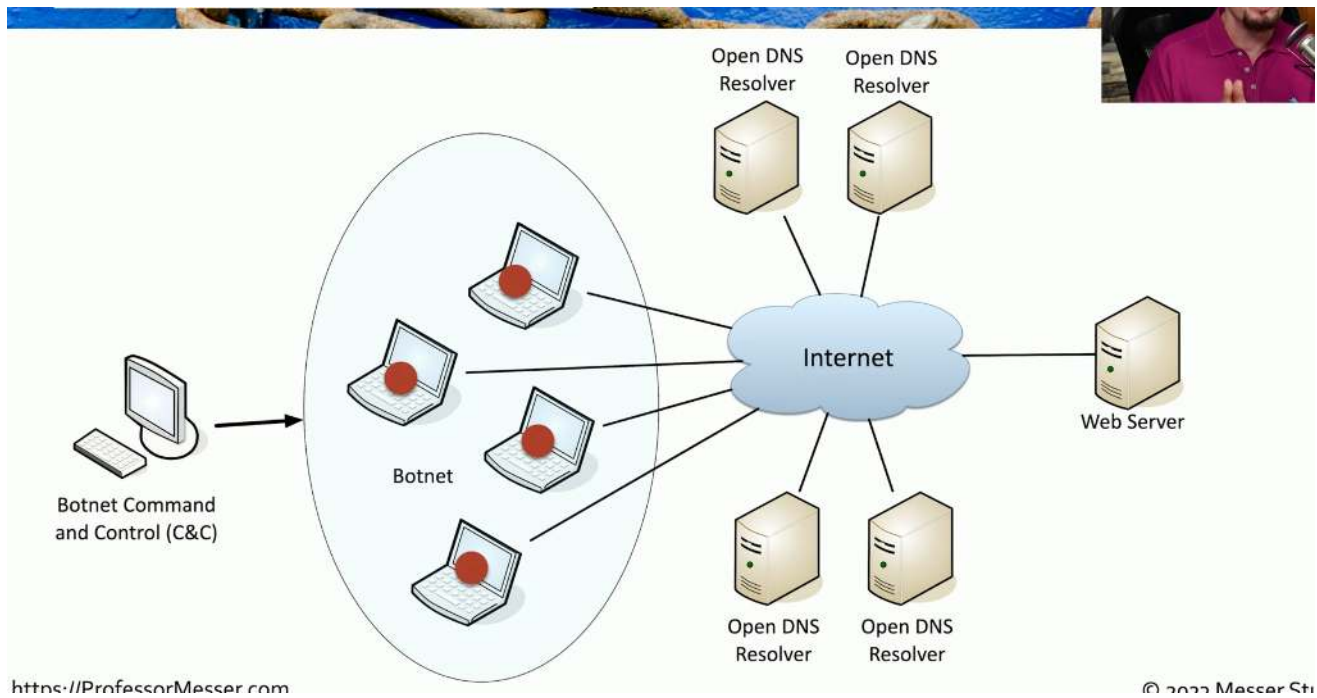
```

An

example of DNS amplification.

The attacker is literally just trying to find a domain name inc.org. You're only sending 15 characters but the return is 1300 characters. This is amplification.





DNS Attacks

DNS poisoning:

Modify the DNS server

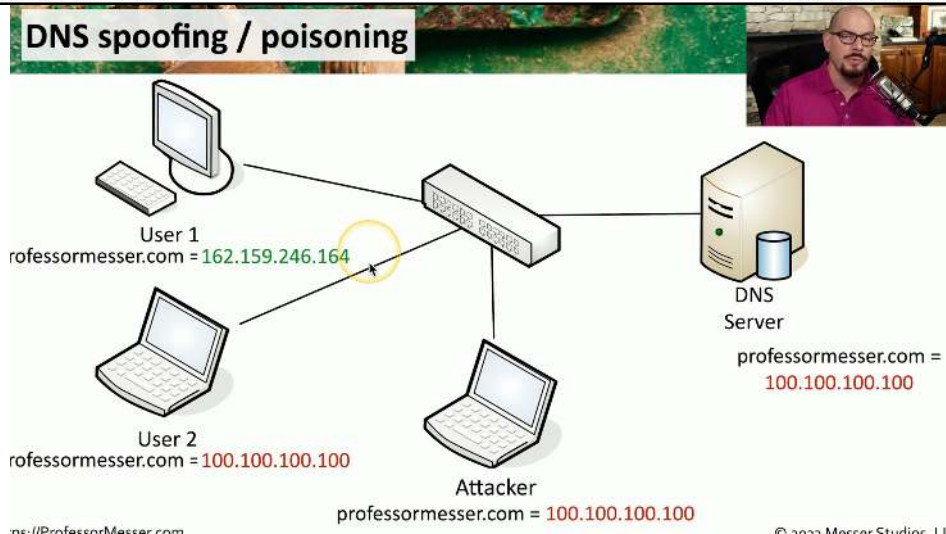
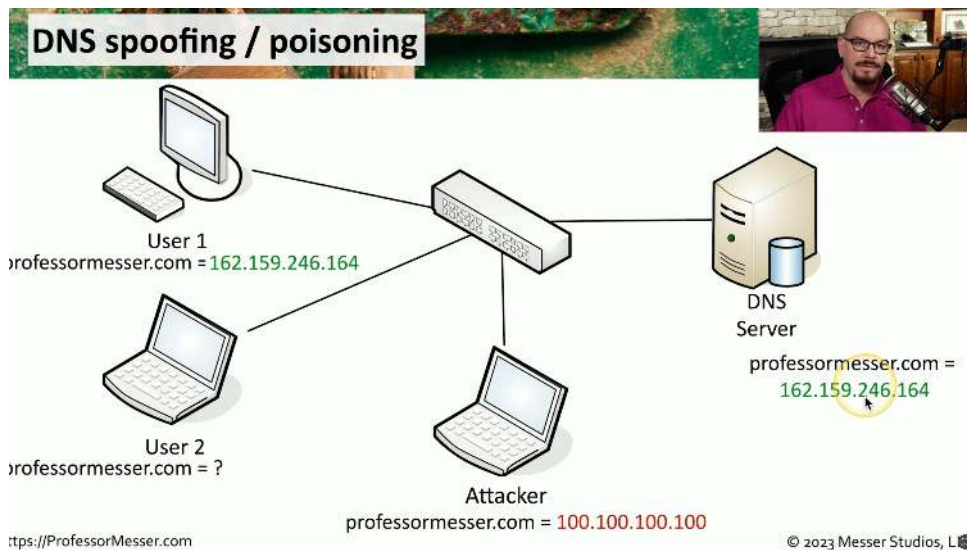
- Requires some crafty hacking

Modify the client host file:

- The host file takes precedent over DNS queries

Send a fake response to a valid DNS request:

- Requires a redirection of the original request or the resulting response
- Real time redirection
- This is an on-path attack



Domain hijacking:

Get access to the domain registration, and you have control where the traffic flows:

- You don't need to touch the actual servers
- Determines the DNS names and DNS IP addresses

Many ways to get into the account:

- Brute force
- Social engineer the password
- Gain access to the email address that manages the account
- The usual things.

Example of domain Hijacking:

Saturday, October 22, 2016, 1pm:

Domain name registrations of 36 domains are changed:

- Brazilian bank
- Desktop domains, mobile domains, and more

Under hacker control for 6 hours:

- The attackers became the bank

5 million customers and 27 billion dollars in assets:

- results of the hack haven't been publicly released

URL hijacking:

Make money from your mistakes:

- There's a lot of advertising on the 'net

Sell the badly spelled domain to the actual owner:

- sell a mistake

Redirect to a competitor:

- Not as common, legal issues

Phishing site:

- Looks like the real site, please login

Infect with a drive-by download:

- You got malware

Types of URL hijacking:
typosquatting / brandjacking
- Take advantage of poor spelling

Outright misspelling:
- Slightly misspelled URL

A typing error:
Try to fool you by misspelling the domain name.

A different phrase:
Slightly different url.

Bottom line be very careful the domain is actually the real one.

Wireless Attacks

It started as a normal day at work and you surf online:
- then you're not

And then it happens again:
- and again

You may not be able to stop it:
- There's almost (nothing) you can do
- Time to get a long patch cable

Wireless deauthentication attack:
- A significant DOS attack

802.11 management frames:

802.11 wireless includes a number of management features:
- Frames that make everything work
- You never see them

Important for the operation of 802.11 wireless:
- how to find access points, manage QoS, associate/disassociate with an access point, etc.

Original wireless standards did not add protection for management frames:
- Sent in the clear, no authentication or validation

Protecting against death attacks:

IEEE has already addressed the problem:
- Updates included with 802.11ac

Some of the important management frames are encrypted:
- Disassociate, deauthenticate, channel switch announcements etc.

Not everything is encrypted:
- Beacons, probes, authentication, association

Radio frequency jamming (RF) jamming:

DOS:

- Prevent wireless communication

Transmit interfering wireless signals:

- Decrease the signal to noise ratio at the receiving device:
- The receiving device can't hear good signal

Sometimes its not intentional:

- Interference, not jamming
- Microwave oven, fluorescent lights can cause jamming

Jamming is intentional:

- Someone want your network not to work

Many different types:

- Constant, random bits / constant, legitimate frames
- Data sent at random times - random date and legitimate frames
- Reactive jamming - only when some else tries to communicate

Needs to be somewhere close:

- Difficult to be effective from a distance

Time to go fox hunting:

- You'll need the right equipment to hunt down the jam
- Directional antenna, attenuator

On path Attacks

On path network attack:

How can an attacker watch without knowing you?

- Formaly known as man in the middle

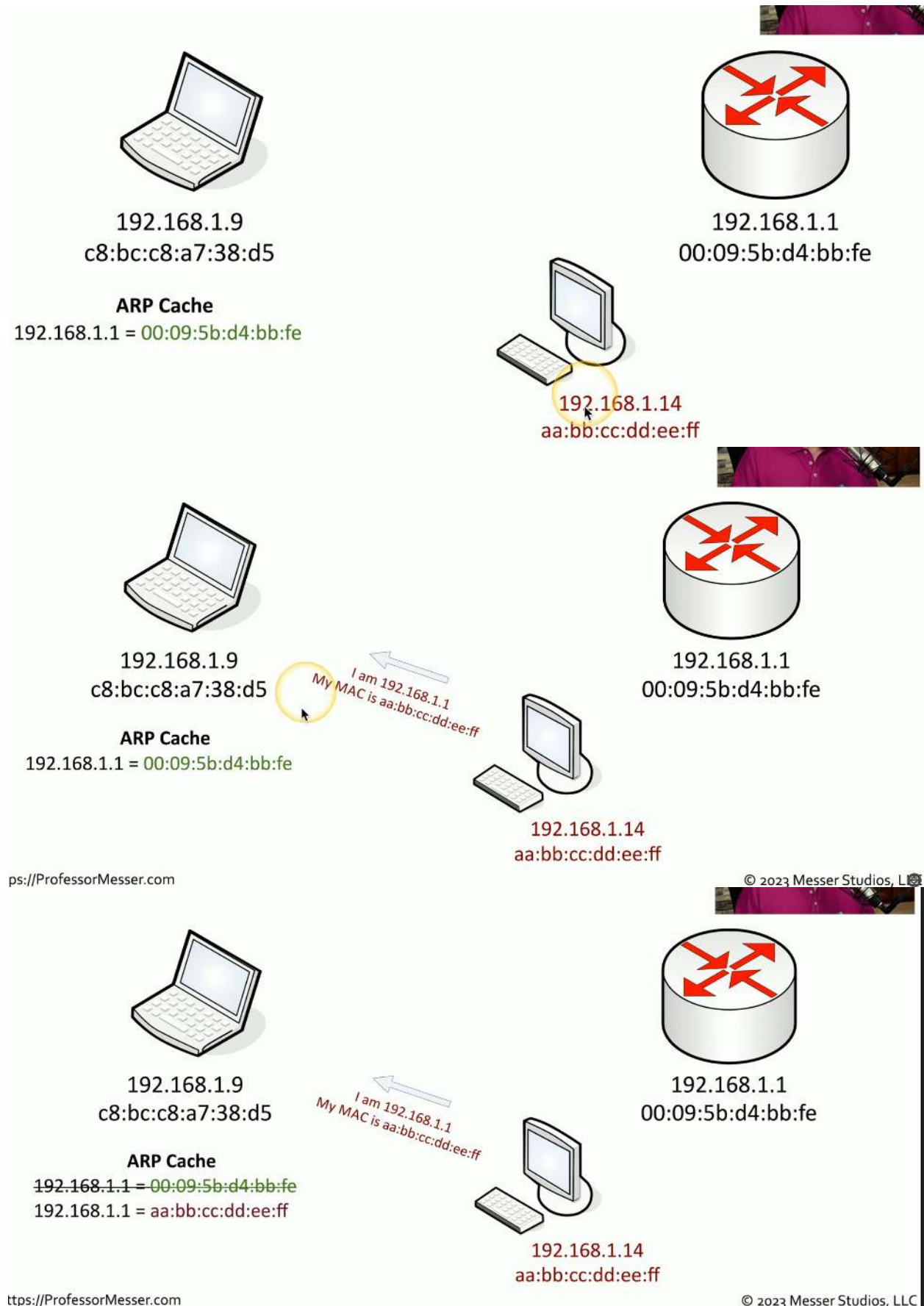
Redirects your traffic:

- Then passes it on to the destination
- You never know your traffic was redirected

ARP poisoning:

- On path attack on there IP subnet
- ARP has no security





On path browser attack:

What if the middleman was on the same computer as the victim?:

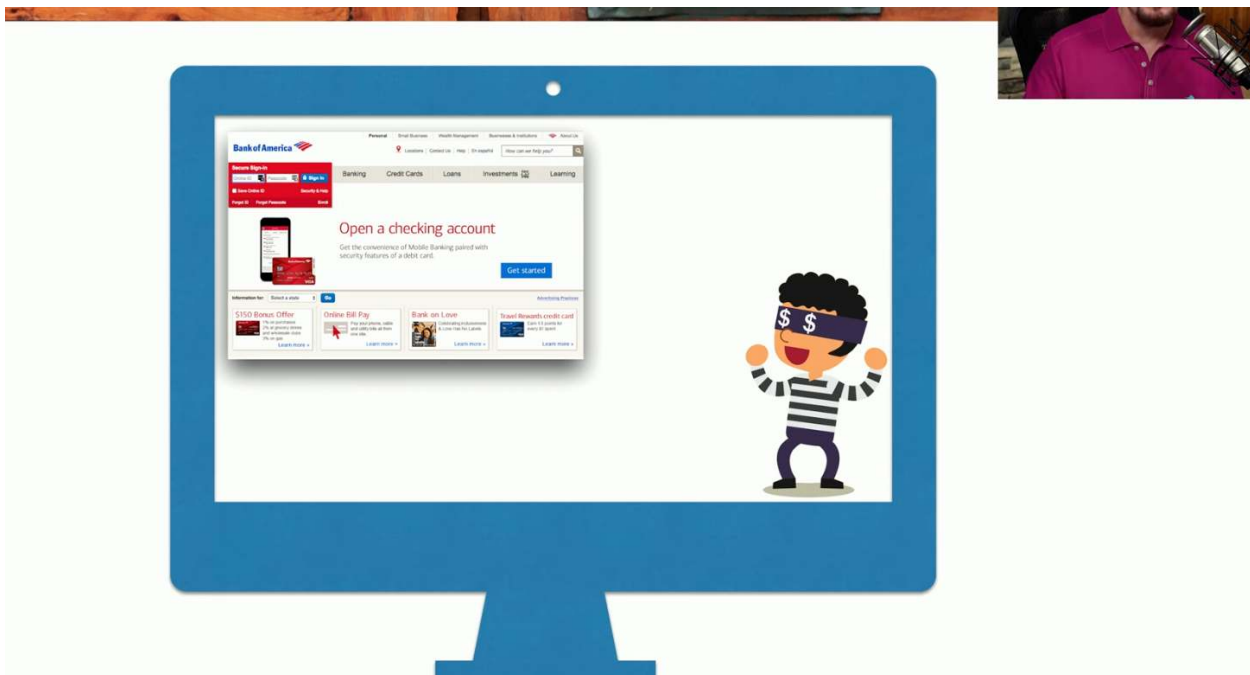
- Malware/Trojan does all of the proxy work
- Formerly known as man in the browser

Huge advantages for the attackers:

- Relatively easy to proxy encrypted traffic
- Everything looks normal to the victim

The malware in your browser waits for you to login to your bank:

- And cleans you out



Replay Attacks

Useful information is transmitted over the network:

- A crafty hacker will take advantage of this

Need access to the raw network data:

- Network tap, ARP poisoning, Malware on the victim computer

They gathered information may help the attacker:

- Replay the data to appear as someone else

This is not an open path attack:

- The actual replay doesn't require the original workstation

Pass the hash example:

- 1st step: Client/ Victim sends a normal authentication request to a server
- 2nd step: The attacker captures authentication (Username and Hashed password)
- 3rd step: Attacker sends his own authentication request using the previously captured information. Aka replay the information captured by a real client.
- 4th step: Username and has match a valid account - Attacker then has access to the server.

How to avoid:

- Use salt or encryption over the network.
- Use a session ID with the password hash to create unique authentication hash every authentication attempt by the client.

Browse cookies and session IDs:

Cookies:

- Information stored on your computer by the browser

Used fir tracking, personalization, session management:

- Not executable, not generally a security risk
- Unless someone gets access to them

Could be considered a privacy risk:

- Lots of personal data in there

Session IDs are often stored in the cookie:

- Maintains sessions. Across multiple browser sessions

Session hijacking (sidejacking):

- 1st step: User provides a username and password and a session ID is sent back to the User
- 2nd step: The attacker hijacks the session ID and uses it to access the server and the server thinks its the user not the attacker and now the attacker has all of the users information on that web server.

Header manipulator:

- Information gathering:
- Wireshark, kismet

Exploits:

- Cross-site scripting

Modify headers:

- Tamper, Firesheep, Scapy

Modify cookies:

- Cookies manager+ (Firefox add-on)

Preventing session hijacking:

Encrypt end to end:

- They can't capture your session ID if they can't see it
- Additional load on the web server (HTTPS)
- Firefox extension: HTTPS everywhere, Force-TLS
- At sites are now HTTPS only

Encrypt end to somewhere:

- At least avoid capture over a local wireless network
- Still in the clear for part of the journey
- Personal VPN

Malicious Code:

Exploiting a vulnerability:

- An attacker can use many techniques:
- Social engineering
- Default creds
- Misconfiguration

These don't require technical skills:

- The door is already locked

There are still ways to get into a well secured system:

- Exploit with malicious code
- Knock the pins out of a door hinge

The attackers use any opportunity:

- The types of malicious code are varied and many

Many different forms:

- Executable, scripts, macro viruses, worms, trojan horse, etc.

Protection comes from many different sources:

- Antimalware
- Firewall
- Continuous updates and patches
- Secure computing labs

Wannacry ransomware:

- Executable exploited a vulnerability in Windows SMBv1
- Arbitrary code execution

British airways cross site scripting:

- 22 lines of malicious javascript code placed on checkout pages
- Information stolen from 380k victims

Estonian central health database:

- SQL injection
- Breached all healthcare information for an entire country

Application Attacks

Code injection:

- Adding your own information into a data stream

Enabled because of bad programming:

- The application should properly handle input and output

So many different injectable data types:

- HTML, SQL, XML,LDAP, etc

Buffer overflow:

Overwriting a buffer memory:

- Spills over into other memory areas

Developers need to perform bounds checking:

- The attackers spend a lot of time looking for openings

Not a simple exploit:

- Takes time to avoid crashing things
- Takes time to make it what you want.

A really useful buffer overflow is repeatable:

- Which means that a system can be compromised

Replay attacks:

Useful information is transmitted over the network:

- A crafty hacker will take advantage of this

Need access to the raw network data:

- Network tap, ARP poisoning, Malware on the victim

The gathered information may help the attacker:

- Replay the data to appear as someone else

This is not an open path attack:

- The actual replay doesn't require an original workstation

Privilege escalation:

Gain higher level access to a system:

- Exploit a vulnerability
- Might be a bug or design flaw

Higher level access means more capabilities:

- This commonly the highest level of access
- This is obviously not good

These are high priority vulnerability patches:

- You want to get these holes closed FAST
- Any user can be an admin

Horizontal privilege escalation:

- User A can access user B resources

Mitigating privilege escalation:

Patch quickly:

- Fix the vulnerability

Update the anti virus/anti-malware software:

- Block known vulnerabilities

Data Execution prevention:

- Only data in executable areas can run

Address space layout randomization:

- Prevent a buffer overrun at a known memory address

Elevation of privilege vulnerability:

CVE-2023-29336:

- Win32k elevation of privilege vulnerability
- May of 2023

Win32k kernel driver:

- Server 2008, 2008 R2, 2012, 2012 R2, 2016
- Windows 10

Attacker would gain SYSTEM privileges:

- The highest level access

Crosssite requests

Crosssite requests are common and legit:

- You visit randomwebsite.com
- Your browser loads text from the website server
- Your browser loads a video or loads pictures from instagram.

HTML on randomwebsite.com directs requests from your browser:

- This is normal and expected
- Most of these are unauthenticated requests

The client and server:

Website pages consist of client side code and server side code:

- Many moving parts

Client side:

- Renders the page on the screen
- HTML, JavaScript

Server side:

- Performs requests from the client
- HTML, PHP
- Transfers money from one account to another
- Posts a video on YouTube

Cross site request forgery:

One click attack, session riding:

- XSRF, CSRF (sea surf)

Takes advantage of the trust that a web app has for the user:

- The website trusts your browser
- Requests are made without your consent or your knowledge
- Attacker posts a Facebook status on your account

Significant web application development oversight:

- The Application should have anti forgery techniques added
- Usually a cryptographic token to prevent forgery

Crosssite request forgery example:

Client is already accessing a bank server through a website.

1st: the Attacker creates a funds transfer request

2nd: Request is sent as a hyperlink to a user who may already logged into the bank website

3rd: Visitor clicks the link and unknowingly sends the transfer request back to the bank website

4th: Bank validates transfer and sends money to the attacker

Directory traversal:

Directory traversal / path traversal:

- Read files from a web server that are outside of the websites file directory
- Users shouldn't be able to browse the windows folder

Web server software vulnerability:

- Won't stop users from browsing past the web server root

Web application code vulnerability:

- Take advantage of badly written code

Cryptographic Attacks

You've encrypted data and sent it to another person:

- Is it really secure?
- How do you know?

The attacker doesn't have the combo (the key):

- So they break the safe (the cryptography)

Finding ways to undo the security:

- There are many potential cryptographic shortcomings
- The problem is often with the implementation.

Birthday attack:

In a classroom of 23 students, what is the chance of two students sharing a bday?

- About 50%
- For a class of 30, the chance is about 70%

In the digital world, this is hash collision:

- A hash collision is the same hash value for two different plaintext.
- find a collision through a brute force

The attacker will generate multiple versions of plaintext to match the hashes:

- Protect yourself with large has output size

Collisions:

Hash digests are supposed to be unique:

- different input data should not create the same hash

MD5 hash:

- Message Digest Algoritm 5
- First Published in April 1992
- Collisions identified in 1996

December 2008: Researchers created CA certificate that appeared legit when MD5 checked:

- Built other certificates that appeared to be legit and issues by RapidSSL

BADD

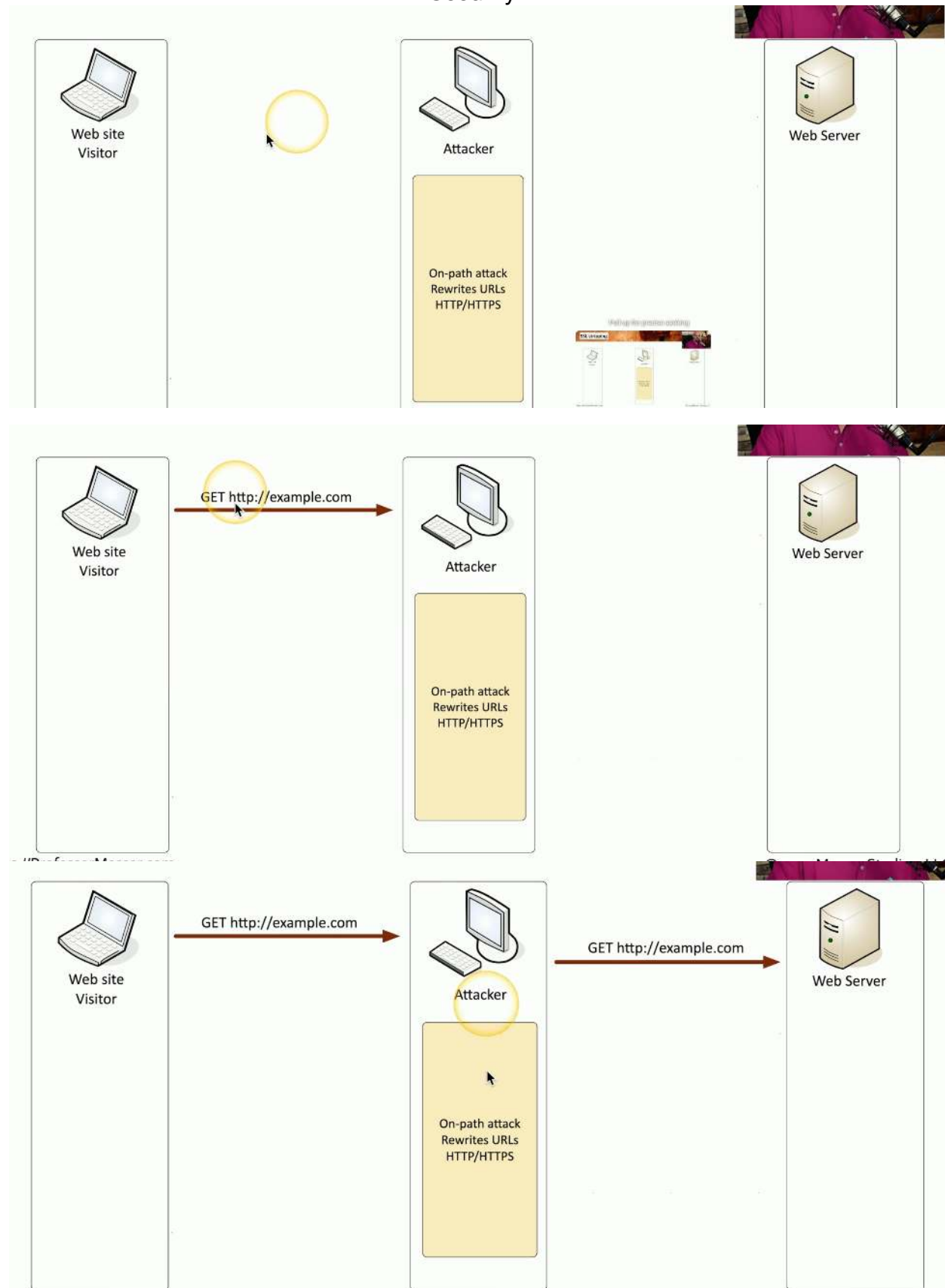
Downgrade attack:

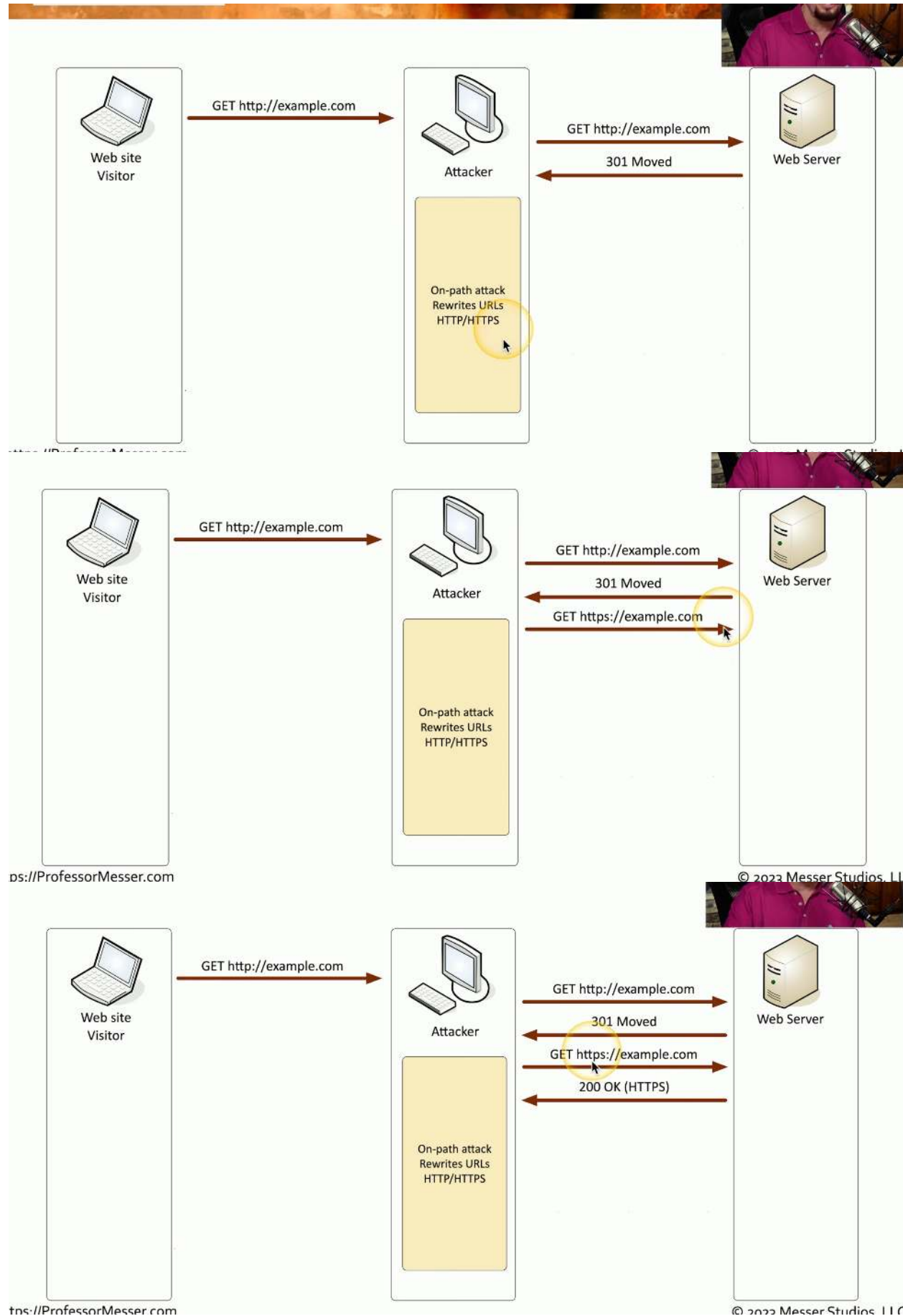
- Instead of using perfectly good encryption, use something not as great:
- Force the systems to downgrade their security

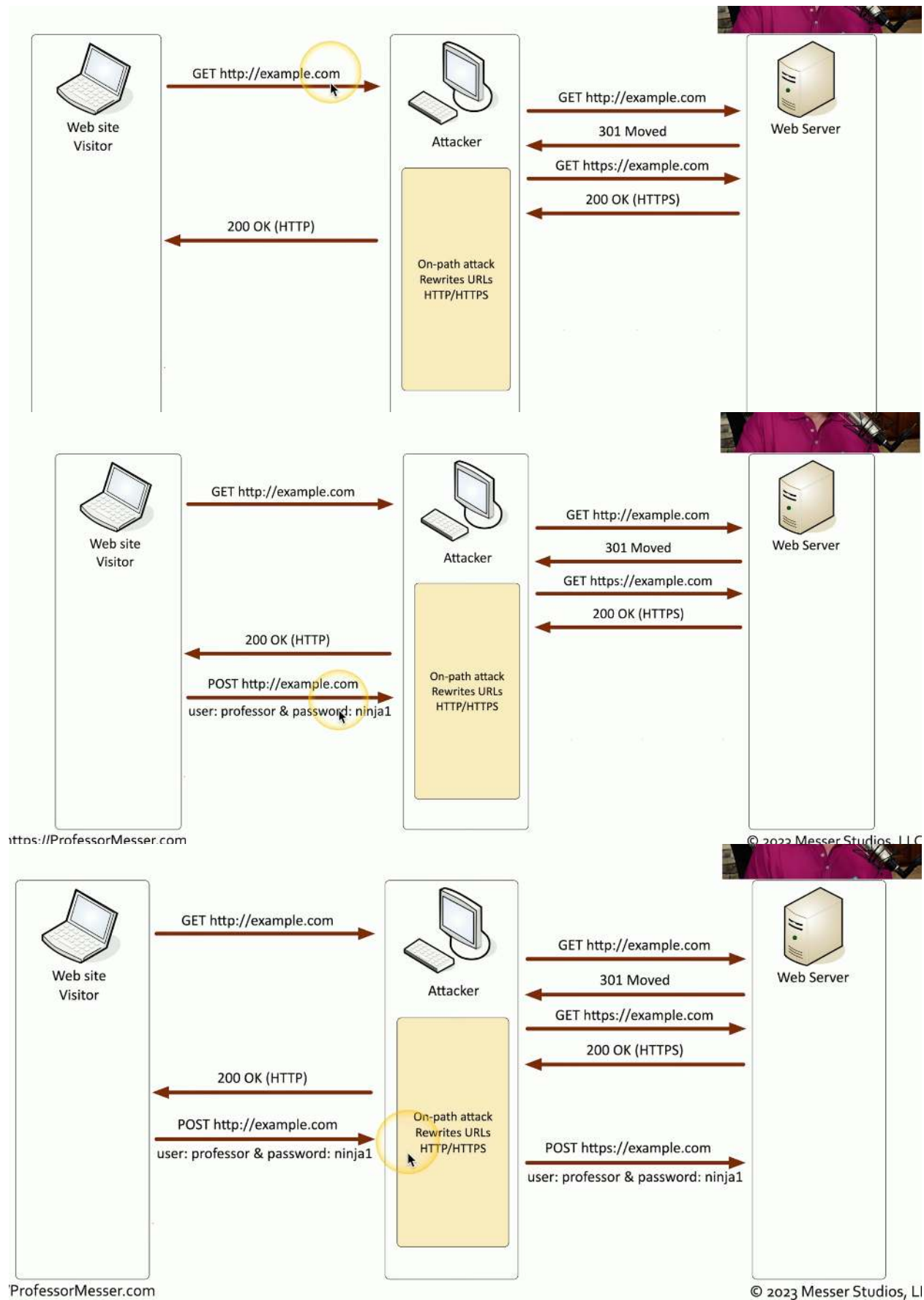
SSL stripping:

- Combines an on path attack with a downgrade attack
- Difficult to implement but big returns for the attacker
- Attacker mist sit in the middle of the conversation
- Victims browser page isn't encrypted
- Strips the S away from HTTPS

VERY BAD







Password Attacks

Plaintext / unencrypted passwords:

Some application store passwords in the clear:

- No Encryption. You can read the stored passwords
- This is rare thankfully

Do not store passwords as plaintext:

- Anyone with access to the password file or database has every credential

What to do if your app saves passwords as plaintext:

- Get a better app

Hashing a password:

Hashes represent data as a fixed-length string of text:

- A message digest, or “fingerprint”

Will not have a collision (hopefully):

- Different inputs will not have the same hash

One way trip:

- Impossible to recover the original message from the digest
- A common way to store passwords

A hash example:

- SHA-256 hash
- Used in many applications

The password file

Different across OS and Apps:

- different hash algorithms

Spraying attack:

Try to login with an incorrect password:

- Eventually you’re locked out

Attack an account with the top 3 or more passwords:

- If they don't work, move to the next account
- No lockouts, no alarms, no alerts

Brute force:

Try every possible password combination until the hash is matched:

This might take some time:

- Strong hashing algorithm slows things down

Brute force attacks - Online:

- Keep trying the login process
- Very slow
- Most accounts will lockout after a number of failed attempts

Brute force the hash - offline:

- Obtain the list of users and hashes
- Calculate a password hash, compare it to a stored hash
- Large computational resource requirement

Indicators of a Compromise

Indicators of Compromise (IOC);

An event that indicates an intrusion:

- Confidence is high
- Hes calling from inside the house

Indicators:

- Unusual amount of network activity
- Change to file hash values
- Irregular international traffic
- Changes to DNS data
- Uncommon login patterns
- Spikes of read requests to certain files

Account lockout:

Credentials are not working:

- It wasn't you this time

Exceeded login attempts:

- Account is auto disabled

Account was admin disabled:

- This would be a larger concern

This may be part of a bigger plan:

- Attacker locks account
- Calls support line to reset password

Concurrent session usage:

Its challenging to be two places at one time:

- Laws of physics

Multiple account logins from multiple location:

- Interactive access from a single user
- You dont have a clone

This can be difficult to track down:

- Multiple devices and desktops
- Automated processes

Blocked Content:

An Attacker wants to stay as long as possible:

- Your system has been unlocked
- Keep the doors and windows open

There's probably a security patch available:

- Time to play keep away

Blocked content:

- Auto update connections
- Links to security patches
- Third party antimalware sites
- Removal tools

Impossible travel:

Authentication logs can be telling:

- Logon and log off

Login from Omaha, Nebraska, United States:

- The company headquarters

Three minutes later, login from Melbourne Australia:

- Alarm bells going crazy

This should be easy to see and identify:

- Log analysis and automation

Resource consumption:

Every attackers action has an equal and opposite reaction:

- Watch carefully for significant change

File transfers use bandwidth:

- An unusual spike at 3am

Firewall logs show the outgoing transfer:

- IP addresses, timeframes

Often the first real notification of an issue:

- The attacker may have been here for months

Resource inaccessibility

The server is down:

- Not responding

Network disruption:

- A cover for the actual exploit

Server outage:

- result of an exploit gone wrong

Encrypted data:

- A potential ransomware attack begins

Brute force attack:

- Locks account access

Out of cycle logging:

- Occurs at an unexpected time

Operating system patch logs:

- Occurring outside of the normal patch day
- Keep that exploited system safe from other attackers

Firewall log activity:

- Timestamps of every traffic flow
- Protocols and applications used

Missing logs:

Log information is evidence:

- Attackers will try to cover their tracks by removing logs:

Information is everywhere:

- Authentication logs
- File access logs
- Firewall logs
- Proxy walls
- Server logs

The logs may be incriminating:

- Missing logs are certainly suspicious
- Logs should be secured and monitored

Published / documented:

The entire attack and data exfiltration may go unnoticed:

- It happens quite often

Company data may be published online:

- The attackers post a portion of all data
- This may be in conjunction with ransomware

Raw data may be released without context:

- Researchers will try to find the source